

QUIZZES SHEET



CERTIFIED ISO/IEC 27001 LEAD IMPLEMENTER
TRAINING COURSE

1. **What does ISO/IEC 27001 provide?**
 - A. Guidelines for implementing an information security management system
 - B. Requirements for implementing an information security management system
 - C. Guidelines and requirements for implementing a privacy information management system
2. **Which of the following statements is correct?**
 - A. Organizations can obtain certification against ISO/IEC 27001
 - B. Organizations can obtain certification against ISO/IEC 27003
 - C. Organizations can obtain certification against ISO/IEC 27005
3. **Which of the following standards provides a reference set of information security controls and guidelines for their implementation?**
 - A. ISO/IEC 27002
 - B. ISO/IEC 27701
 - C. ISO/IEC 27005
4. **In what areas do ISO/IEC 27001 and the General Data Protection Regulation (GDPR) overlap?**
 - A. PII collection and processing and the rights of data subjects
 - B. Data confidentiality, availability, and integrity, and risk assessment
 - C. Physical security, access control, and continual improvement
5. **What does STAR, a three-tiered cloud provider assurance program, stand for?**
 - A. Security, Trust, Assurance, and Risk
 - B. Security, Task, Action, and Results
 - C. Security, Transparency, Assurance, and Response

Quiz 2: Information security management system (ISMS)

1. **A management system is a set of interrelated or interacting elements of an organization to establish policies, objectives, and processes to achieve those objectives.**
 - A. True
 - B. False
2. **What is an integrated management system (IMS)?**
 - A. A management system that integrates all the guidelines and best practices so as to enable the achievement of its purpose and mission
 - B. A management system that integrates all the components of a business into a coherent system so as to enable the achievement of its purpose and mission
 - C. A management system that integrates all frameworks and resources so as to enable the achievement of its purpose and mission
3. **Which of the following is a benefit of an effective ISMS?**
 - A. Reducing information security risks
 - B. Completely eliminating information security risks
 - C. Preventing all data breaches
4. **Annex A of ISO/IEC 27001 consists of 114 controls divided into five themes.**
 - A. True
 - B. False
5. **How is the process approach defined as?**
 - A. A systematic approach for an organization's information security to achieve business objectives
 - B. Integration of the ISMS into the context of commercial activities and processes across the organization
 - C. Identification and orderly management of processes within an organization

Quiz 3: Fundamental concepts and principles of information security

1. **Which of the following is considered a virtual organizational asset?**
 - A. Email accounts

- B. Intellectual property
 - C. Digital customer identity
2. **Which of the following statements regarding information security is correct?**
 - A. Information security entails the protection of the confidentiality, integrity, and availability of information regardless of its type and form
 - B. Information security entails the protection of the confidentiality, integrity, and availability of digital data only
 - C. Information security entails the protection of the confidentiality, integrity, and availability of physical data only
 3. **What does confidentiality require?**
 - A. That only authorized users have access to protected and sensitive information
 - B. That information is accurate and complete and not modified during storage or transit
 - C. That information is accessible when, where, and as required and to the person requiring
 4. **Which of the following is NOT an example of a threat?**
 - A. Theft of media or documents
 - B. Unencrypted data
 - C. Unauthorized use of a system
 5. **Which information security principle would likely be impacted by a service interruption?**
 - A. Availability
 - B. Confidentiality
 - C. Integrity
 6. **Vulnerability is a weakness of an asset or control that can be exploited by one or more threats.**
 - A. True
 - B. False
 7. **What type of controls are the segregation of duties, job rotations, and approval processes?**
 - A. Technical controls
 - B. Managerial controls
 - C. Administrative controls

8. **What function does the control for the separation of the development, testing, and operating environments have?**
 - A. Preventive
 - B. Detective
 - C. Corrective
9. **An organization has installed alarm systems on its premises. What type of control is this, and what function does it have?**
 - A. Administrative, preventive
 - B. Managerial, corrective
 - C. Technical, detective
10. **Assets can have _____ that can be exploited by _____.**
 - A. Threats, vulnerabilities
 - B. Vulnerabilities, threats
 - C. Threats, risks

Quiz 4: Initiation of the ISMS implementation

1. **Which implementation approach includes the application of best practices in project management?**
 - A. Business approach
 - B. Iterative approach
 - C. Systematic approach

2. **What is the correct definition of the term project?**
 - A. A unique process consisting of a set of coordinated and controlled activities to achieve an objective conforming to specific requirements
 - B. The smallest identified object of work in an organization
 - C. The process of planning, organizing, controlling, and reporting of a set of activities to achieve objectives
3. **Which of the following statements regarding the ISMS is correct?**
 - A. New technologies should be integrated when implementing the ISMS to optimize processes
 - B. The roles and responsibilities of interested parties relevant to the ISMS should be defined after the implementation process
 - C. The ISMS should be integrated into existing processes of the organization
4. **Which of the following is NOT a factor that determines the approach for implementing an ISMS?**
 - A. Maturity level of controls and processes
 - B. Applicable laws and regulations
 - C. Dependence on technology
5. **What is the iterative approach?**
 - A. Overall implementation of the ISMS processes, not by isolating certain processes
 - B. Rapid implementation of the ISMS by adhering to the minimum requirements of the standard and proceeding with continual improvement thereafter
 - C. Harmonization of the ISMS with other management systems established within the organization

Quiz 5: Understanding the organization and its context

1. **Why is it important to understand the mission, objectives, values, and strategies of an organization?**
 - A. To facilitate the internal audit process
 - B. To create a map of all the processes
 - C. To ensure consistent alignment with information security goals
2. **What does ISO/IEC 27001 require for establishing information security objectives, among others?**

- A. To involve all stakeholders
 - B. To retain documented information
 - C. To evaluate their achievement quarterly
3. _____ is a person or an organization that can affect, be affected by, or perceive itself to be affected by a decision or activity.
- A. A customer
 - B. An interested party
 - C. A provider
4. Which of the following is NOT an element that should be considered when analyzing the organization's internal context?
- A. Competitors
 - B. Governance and organizational structure
 - C. Information flows and decision-making processes
5. Which of the following requirements of interested parties must organizations consider, according to clause 4.2 of ISO/IEC 27001?
- A. Legal and regulatory requirements
 - B. Climate change requirements
 - C. Both A and B

Quiz 6: ISMS scope

1. What factors can affect the ISMS scope, among others?
- A. Support functions, such as IT services and software applications
 - B. The outsourced functions
 - C. Both A and B
2. When determining the ISMS scope, the organization must consider interfaces and dependencies between the activities it performs and those performed by other organizations.
- A. True

- B. False
3. **Which of the following dimensions should be considered when defining the boundaries of the ISMS scope?**
- A. Information system boundaries
 - B. Physical boundaries
 - C. Both A and B
4. **Which ISMS boundaries can organization determine by evaluating the responsibilities of decision-makers and their areas of influence?**
- A. Organizational
 - B. Physical
 - C. Information system
5. **Which of the following statements regarding the ISMS scope is correct?**
- A. The ISMS scope should be classified as confidential information
 - B. The ISMS scope does not have to consider the needs and expectations of interested parties
 - C. The ISMS scope should be available as documented information
6. **What is the recommended process for making changes in ISMS scope?**
- A. Changes must be automatically implemented if the organization is certified by a conformity assessment body (CAB)
 - B. Changes should be justified and approved during a management review
 - C. Changes should be documented and be approved only by the ISMS project manager

Scenario-based quiz 1

YoMedia is an insights company headquartered in Milan, Italy, providing research services worldwide. The company collects, analyzes, and interprets customer data to offer solutions to its clients based on the results. Due to the nature of their services, *YoMedia*'s top management decided to implement an information security management system (ISMS) based on the requirements of ISO/IEC 27001 to ensure information confidentiality, availability, and integrity. Additionally, as a business operating within the European Union (EU), *YoMedia* is committed to adhering to the General Data Protection Regulation (GDPR) to safeguard the privacy rights of its customers.

To effectively implement the ISMS and ensure GDPR compliance, *YoMedia* mobilized a dedicated ISMS team. The team comprised members from various departments, including IT,

Legal, Compliance, and Customer Support. Their responsibility was to effectively implement the ISMS and ensure GDPR compliance.

Initially, the ISMS team identified all systems and processes that handle customer data and information, ensuring their inclusion within the ISMS scope. The scope covered the organizational, information, and communication technology, and physical aspects. To define the boundaries of the ISMS, the team utilized the approach of adopting the boundaries used by the users themselves. They also considered geographical boundaries and temporal boundaries.

Additionally, the ISMS team conducted a thorough analysis of *YoMedia*'s strengths and weaknesses with the aim of determining where the organization should invest its resources. The team conducted interviews with the employees of the company and used various techniques to gather information on the existing processes, procedures, policies, and controls. During the analysis, the team discovered that *YoMedia* uses access control software that allows only authorized users to access sensitive information. However, their software application and programs have a complicated user interface that results in high number of data input errors by the personnel on a daily basis. Furthermore, while conducting interviews, they learned that there were several employees from different departments who had not received any security training.

Based on their findings, the ISMS team concluded that the company needs to redefine its training needs and simplify its user interface to address the identified issues effectively.

Based on the scenario above, answer the following questions:

1. **By using the boundaries preferred by the users, which approach did the ISMS team utilize to define the organizational boundaries?**
 - A. The realistic approach
 - B. The common approach
 - C. The ad hoc approach
2. **The ISMS team used the temporal boundary method. What does this method include?**
 - A. Time and desktop programs
 - B. Offices of the organization
 - C. Both A and B
3. **Which of the situations presented in the scenario is considered an information security threat?**
 - A. The data input error by the personnel
 - B. The complicated user interface
 - C. The use of programs or applications by personnel on a daily basis
4. **Which approach did the ISMS team apply to analyze the organization's context?**

- A. PEST analysis
 - B. Porter's Five Forces analysis
 - C. SWOT analysis
5. **Several employees from different departments in YoMedia did not receive any security trainings. What does this indicate?**
- A. The presence of a threat that is related to the possible functions of the company
 - B. The presence of an information security risk expressed as the combination of the impact and occurrence of an incident in the company
 - C. The presence of a vulnerability in the existing personnel procedures of the company

Quiz 7: Leadership and project approval

1. **What resources are usually necessary for the implementation of an ISMS, among others?**
 - A. Marketing, sales, advertising
 - B. Inventory management systems and manufacturing equipment
 - C. People, information, facilities, finance
2. **Why do some projects in highly competitive environments prioritize minimal upfront planning?**
 - A. To accommodate stakeholder feedback and new technology
 - B. To minimize the cost of delay and speed up time to market
 - C. To evaluate environmental effects and inform design decisions for sustainability
3. **What should an ISMS project plan include?**
 - A. Current problems and pending decisions
 - B. All current projects and subprojects with their milestones
 - C. Both A and B
4. **An ISMS project team usually consists of the project champion, project manager, project management team, project team, and interested parties.**
 - A. True

B. False

5. Who should approve the implementation of the ISMS?

- A. All interested parties
- B. The organization's top management
- C. The head of the IT Department

Quiz 8: Organizational structure

1. According to ISO/IEC 27001, who must ensure that the responsibilities and authorities for roles relevant to information security are assigned and communicated?

- A. Human resources
- B. Top management
- C. Heads of departments

2. What is the main advantage of the traditional organizational structure?

- A. Clear separation between the roles and responsibilities of information security and IT
- B. Issues are only focused on strategic security and non-technology aspects
- C. Technology and information security are part of a single department

3. What is the role of the executive committee in the context of the ISMS?

- A. Conducting daily meetings with employees to discuss information security matters
- B. Serving as the body of guidance, control, validation, decision-making, and arbitration for the ISMS
- C. Establishing minimum meeting frequencies for all committees within the organization

4. Which of the following is NOT a key committee in an organization's ISMS implementation project?

- A. Information security committee
- B. Operational committee
- C. Stakeholders committee

5. **Who holds the main responsibility for ensuring the proper functioning of the ISMS and the security controls?**
- A. The internal auditor
 - B. The information security committee
 - C. The operational committee

Quiz 9: Analysis of the existing system

1. **What is a gap analysis?**
- A. A technique used to determine the steps to move from a current state to a desired future state
 - B. A technique used to determine the ways in which a process might potentially fail, with the objective of eliminating the likelihood of such a failure
 - C. A technique used to evaluate the organization against its competitors to establish a comprehensive long-term strategy
2. **An organization has reported that its processes have reached a top-quality level following continual improvement and compliance with best practices. What level of maturity is this?**
- A. Quantitatively managed
 - B. Optimized
 - C. Initial
3. **Which of the following is NOT a level of maturity?**
- A. Quantitatively managed
 - B. Nonexistent
 - C. Unmanaged
4. **Which of the following is NOT used as a method for collecting information about an organization's existing management system?**
- A. Reviewing the organization's financial statements and tax records
 - B. Sending questionnaires to a group of people who represent the interested parties
 - C. Using scan tools to detect technical vulnerabilities and establish a list of network assets
5. **Which of the following is an effective visual tool that organizations can use to present the gap analysis results?**

- A. Radar chart
- B. Ishikawa diagram
- C. Cause-and-effect diagram

Quiz 10: Information security policy

1. **According to ISO/IEC 27001, who is responsible for establishing the information security policy?**
 - A. The top management
 - B. The ISMS project manager
 - C. The information security manager
2. **What is the difference between a policy and a guideline?**
 - A. A policy states the intentions and direction of an organization, whereas a guideline states how something should be done
 - B. A policy is a type of a guideline that provides guidance for different topics
 - C. A policy is a document stating how something should be done, whereas a guideline is an explanation of procedures
3. **Which type of policies specifies the internal requirements of another policy and covers a particular target audience?**
 - A. High-level general policies
 - B. High-level specific policies
 - C. Topic-specific policies
4. **Which of the following is a high-level specific policy?**
 - A. Incident management policy
 - B. Information security policy
 - C. Policy on cryptography
5. **What is the first phase of the information security policy development life cycle?**
 - A. Policy construction
 - B. Policy monitoring and maintenance
 - C. Risk assessment

Quiz 11: Risk management (Part 1)

- 1. What does ISO/IEC 27005 provide?**
 - A. Requirements for information security risk management
 - B. Guidelines for managing any type of risk, regardless of its nature or consequences
 - C. Guidelines for information security risk management
- 2. What should be considered when selecting a risk assessment methodology when implementing an ISMS, among others?**
 - A. The scalability of the methodology to integrate various project sizes and complexities
 - B. Compatibility of the methodology with all the criteria of ISO/IEC 27001
 - C. Residual risks documented in the risk treatment plan
- 3. Which of the following best defines primary/business assets in the context of an organization's information security?**
 - A. Primary/business assets include physical infrastructure like buildings and warehouse
 - B. Primary/business assets are components of the information system that support other asset
 - C. Primary/business assets refer to information or processes of value for an organization
- 4. Which phase of risk assessment aims to find, recognize, and describe risks?**
 - A. Risk identification
 - B. Risk evaluation
 - C. Risk analysis
- 5. Which of the following processes involves comparing the results of the risk analysis with the risk criteria to determine whether the risk and its magnitude is acceptable or tolerable?**
 - A. Risk treatment
 - B. Risk evaluation
 - C. Risk acceptance

Quiz 12: Risk management (Part 2)

- 1. Which process modifies risk?**
 - A. Risk evaluation
 - B. Risk identification
 - C. Risk treatment

- 2. The organization has decided to outsource the payment process to an external organization in order to reduce the risk. Which risk treatment option did the organization select?**
 - A. Risk retention
 - B. Risk sharing
 - C. Risk modification

- 3. Residual risk is the level of risk before any controls or measures are taken.**
 - A. True
 - B. False

- 4. What is an objective of risk communication?**
 - A. To promote awareness and understanding of risk
 - B. To delegate risk management responsibilities to external parties
 - C. To prioritize risk management over organizational objectives

- 5. Which of the following factors that may influence risks should organizations continually monitor, among others?**
 - A. New sources of risk
 - B. Changes in laws and regulations
 - C. Both A and B

Quiz 13: Statement of Applicability

- 1. According to ISO/IEC 27001, what must the Statement of Applicability contain?**
 - A. The timeframes for auditing the controls
 - B. The justification for excluding any of the Annex A controls
 - C. The names of individuals responsible for the effectiveness of the controls
- 2. How does an organization select the security controls of ISO/IEC 27001, Annex A?**
 - A. Based on the risk assessment results
 - B. Based on the top management's decision
 - C. Based on the internal audit report
- 3. ISO/IEC 27001 requires that the organization select its security controls only from Annex A.**
 - A. True
 - B. False
- 4. Which of the following is a common reason for excluding controls of Annex A of ISO/IEC 27001?**
 - A. Streamline of the organization's operational processes and complexity reduction
 - B. Violation of legal, statutory, or contractual requirements
 - C. Potential conflicts with industry best practices and guidelines

Scenario-based quiz 2

DetSearch is a leading research and development company headquartered in Barcelona, Spain. It specializes in providing comprehensive data solutions that allow clients to seize lucrative market opportunities. Its services include in-depth market research, consumer behavior studies, trend forecasting, competitive intelligence, data visualization and reporting, and strategic consultation, all driven by advanced data analytics and insights to empower clients in making informed decisions and achieving business success.

The top management of *DetSearch* recently decided to prioritize compliance to information security statutory and regulatory requirements. As such, to ensure information security and uphold the trust of esteemed clients, the top management decided to implement a robust information security management system (ISMS) based on ISO/IEC 27001.

As the company initiated the ISMS implementation, the focus remained on safeguarding data of all formats and ensuring the confidentiality, integrity, and availability of clients' sensitive information. The top management assigned the role of the ISMS project manager to Carla, the chief information security officer, because of her expertise in information security and project management. She was responsible for leading the implementation through all phases, including the drafting of the ISMS project plan, and ensuring management approval. Additionally, the top management mobilized the ISMS team comprising only information security experts.

First, the top management identified the resources necessary for the ISMS implementation, including information, transportation, people, information and communication technology (ICT) systems, facilities, equipment, and finances. However, they did not include partners and suppliers as a necessary resource, as they did not deem it necessary.

Afterward, the ISMS team performed a gap analysis. They followed a systematic approach, starting with determining the organization's current state by identifying the existing processes and information security controls in place. Subsequently, they set specific targets for each information security control. After obtaining the gap analysis results, Carla and the ISMS team were well-equipped to plan and prioritize the necessary actions to strengthen the information security controls and ensure the confidentiality, integrity, and availability of data throughout all *DetSearch's* operations.

Next, Carla drafted the information security policy. She defined the policy components, drafted the policy sections, and validated the content and format of the policy.

The ISMS team conducted a risk assessment. As part of the risk analysis, the ISMS team ensures clarity and consistency by recording clear explanations of the terms used and the basis for each criterion. They recognize the importance of avoiding individual biases and divergent opinions, ensuring repeatability and reproducibility by documenting explanatory notes for assessed values.

Based on the scenario above, answer the following questions:

1. ***DetSearch* established the ISMS project team comprising only information security experts. Is this a good practice to follow?**
 - A. No, while establishing the ISMS project team comprising of only experts in the information security could bring valuable knowledge in the information security and technology to *DetSearch*, it is not a good practice in its entirety
 - B. Yes, including individuals from different background in the ISMS project team would only slow down the decision-making process for *DetSearch*, leading to a less efficient implementation of security measures
 - C. Yes, having a team of only experts in the information security would ensure that the ISMS would be implemented smoothly
2. **Clara identified the resources for the ISMS implementation. Is this a good practice?**
 - A. Yes, the ISMS project manager is responsible for identifying the necessary resources for the ISMS implementation
 - B. No, everyone affected by the ISMS should take part in identifying the necessary resources for the ISMS implementation
 - C. No, the ISMS team should identify the necessary resources for the ISMS implementation
3. **Did the ISMS team correctly follow the systematic approach of conducting the gap analysis?**
 - A. No, the ISMS team should have firstly focused on setting specific targets for each information security control before conducting the gap analysis to ensure a more accurate assessment
 - B. No, the ISMS team should have skipped the gap analysis as it is an unnecessary step that only adds complexity to the ISMS implementation
 - C. Yes, the ISMS team correctly followed the systematic approach of conducting the gap analysis
4. **During the process of drafting the information security policy, did Carla follow all the essential steps?**
 - A. No, Carla did not validate the policy with the interested parties

- B. No, Carla failed to consider the integration of the operational specifications and references to specific products in the policy
 - C. Yes, Carla followed all the essential steps to draft the policy
5. **Which risk analysis technique did the ISMS team use?**
- A. Qualitative risk analysis
 - B. Semi-qualitative risk analysis
 - C. Quantitative risk analysis

Quiz 14: Selection and design of controls

1. **What does an organization's security architecture represent?**
 - A. A set of practices used to address security requirements at a tactical level
 - B. A set of practices used to address security requirements at an operational level
 - C. A set of practices used to address security requirements at a system level
2. **Which of the following security services aim to facilitate user identification and support shared authentication across the organization?**
 - A. Boundary control
 - B. Access control
 - C. Cryptographic
3. **What are the six cascading levels covered in the SABSA matrix for security architecture development?**

- A. Elements, purpose, procedures, personnel, area, and schedule
 - B. Functions, planning, procedures, personnel, geography, and duration
 - C. Asset, motivation, process, people, location, and time
- 4. Which of the following steps should organizations take when preparing for the implementation of information security controls, among others?**
- A. Prepare the required documented information
 - B. Conduct a cost analysis
 - C. Both A and B
- 5. Why should organizations involve employees in the process of drafting information security procedures and policies?**
- A. Because it saves time and resources during the drafting process
 - B. Because it motivates them to contribute in the implementation of the information security controls
 - C. Because it is a requirement of ISO/IEC 27001
- 6. ISO/IEC 27001 provides a specific documentation method to be used for designing and describing controls.**
- A. True
 - B. False

Quiz 15: Implementation of controls

- 1. In how many themes are the 93 controls of Annex A grouped?**
 - A. Five
 - B. Three
 - C. Four
- 2. What is the main purpose of control 6.1 *Screening of Annex A of ISO/IEC 27001*?**
 - A. To ensure that all personnel are eligible and suitable for their roles
 - B. To ensure that employees and contractors are aware of and fulfil their information security responsibilities
 - C. To protect the organization's interests as part of the process of any changes in employment
- 3. Who should have access to documented operating procedures for information processing facilities?**
 - A. Only the top management
 - B. Only the person responsible for operating procedures
 - C. Any user that needs them
- 4. What is the main requirement of control 8.34 *Protection of information systems during audit testing of Annex A*?**
 - A. The tester and appropriate management must appropriately manage test information
 - B. The tester and appropriate management must plan and agree on audit tests and other assurance activities involving assessment of operational systems
 - C. The tester must separate and secure the development, testing, and production environments
- 5. What is the purpose of control 5.7 *Threat intelligence of Annex A*?**
 - A. To provide awareness of the organization's threat environment so that the appropriate mitigation actions can be taken
 - B. To ensure appropriate flow of information
 - C. To ensure information security risks related to deliverables are effectively addressed in project management throughout the project life cycle

Quiz 16: Management of documented information

1. **Among others, what must organizations do, to comply with clause 7.5.1 *Documented information* of ISO/IEC 27001?**
 - A. Develop a procedure for the control of the documented information
 - B. Develop a guide for the control of the documented information that is accessible only by the top management
 - C. Develop a comprehensive database for the control of the documented information, storing all records in an encrypted format
2. **In order to comply with ISO/IEC 27001, organizations should establish a complex document control system.**
 - A. True
 - B. False
3. **What does a procedure describe?**
 - A. An outline of specific instructions on the steps to be taken
 - B. A detailed instruction on the use or installation, maintenance, or operation of something to an actual description of policies
 - C. A detailed explanation of the functioning of a process
4. **What is the main purpose of the approval stage in the process of controlling and managing documents for the ISMS?**
 - A. To distribute the document to all interested parties
 - B. To finalize and sign off on the documents
 - C. To identify opportunities for improvement
5. **What are the benefits of a documented information management system?**
 - A. Facilitating access to, referencing, disseminating, and archiving documents
 - B. Ensuring traceability of the documented information
 - C. Both A and B

Quiz 17: Trends and technologies

1. **Which of the options below is NOT part of the three V's of big data?**

- A. Volume
 - B. Velocity
 - C. Variance
2. **Structured data are based on binary data and do not have a predefined data model.**
 - A. True
 - B. False
 3. **Which of the following is an example of unstructured data?**
 - A. MongoDB
 - B. SQL databases
 - C. Microsoft Excel files
 4. **Which of the following is a benefit of weak artificial intelligence?**
 - A. Automated tasks
 - B. Problem-solving
 - C. Use of critical thinking
 5. **Linear regression, decision tree, and logistic regression are some of the essential algorithms utilized by:**
 - A. Machine learning
 - B. Artificial intelligence
 - C. Cloud computing
 6. **In which of the following cloud deployment models are the same computing resources shared among multiple customers?**
 - A. Private cloud
 - B. Public cloud
 - C. Hybrid cloud
 7. **What services are delivered by the cloud provider, among others, when using infrastructure as a service (IaaS)?**
 - A. Virtualization and network
 - B. Runtime and application
 - C. Middleware and data
 8. **Among the greatest impacts of new technology in information security is the fact that passwords will not be used any longer, as the new technology requires the use of more secure authentication methods, such as the use of biometrics, Identity as a Service (IDaS), and Fast Identity Online (FIDO).**
 - A. True

B. False

9. Which of the following statements regarding machine learning is correct?

- A. Machine learning is synonymous to artificial intelligence and the terms can be used interchangeably
- B. Machine learning delivers hosted services over the internet
- C. There are three types of machine learning: supervised machine learning, unsupervised machine learning and reinforcement learning

Quiz 18: Communication

1. Which information security principle can transparency compromise during a communication if not addressed properly?

- A. Integrity
- B. Confidentiality

- C. Availability
- 2. **Which of the following is an example of a communication objectives?**
 - A. Establish transparent communication with interested parties to improve credibility and reputation
 - B. Communicate the performance of the ISMS
 - C. Both A and B
- 3. **The approaches or tools to use to conduct communication activities largely depend on whether organizations aim to consult, understand, inform, or involve target groups.**
 - A. True
 - B. False
- 4. **What should organizations consider regarding communications relevant to the ISMS?**
 - A. The type of encryption used for communication, the frequency of communication, and the communication channels
 - B. The physical location of communication servers, the security protocols in place, and the bandwidth capacity for communication
 - C. The content of communication, the timing of communication, the intended recipients of communication, the responsible individuals for communication, and the processes used for communication
- 5. **Which principle of successful communication requires to provide relevant information to interested parties using styles, language, and media that align with their preferences and needs, enabling them to fully participate?**
 - A. Transparency
 - B. Appropriateness
 - C. Credibility

Quiz 19: Competence and awareness

- 1. **How can organizations ensure employee competence for the proper functioning of the ISMS?**
 - A. On the basis of appropriate education, training, or experience
 - B. On the basis of a thorough understanding of the information security policy
 - C. On the basis of tenure and seniority within the organization

2. **People _____ is the encouragement of employees to acquire new or advanced _____ by creating learning and training opportunities with circumstances to deploy the outcomes that have been acquired.**
 - A. Mentoring, leadership skills
 - B. Recognition, technological knowledge
 - C. Development, competence
3. **How can the competence gap be determined?**
 - A. By comparing the previous and current competence levels
 - B. By comparing current and required competence levels
 - C. Based on the training and awareness programs output
4. **An employee has received an email with a link that, when clicked, redirects them to a malicious website. The IT manager identifies the issue and immediately blocks the email forward system. What action should the organization take to prevent similar situations from recurring?**
 - A. Conduct an awareness program to address social engineering and risks associated with emails
 - B. Conduct a training program to inform the employees about the risks associated with phishing and spams
 - C. Conduct an awareness program to address problems related to access control
5. **Which of the following topics is a main area that should be addressed during an awareness program?**
 - A. The implementation of antivirus software
 - B. Documented information required by the ISMS
 - C. The use of passwords

Quiz 20: Management of security operations (Part 1)

1. **What does the measurement of change results include?**
 - A. Generating the change metrics
 - B. Verifying the change success
 - C. Allocating the required time needed for the change
2. **Which of the following statements is correct?**
 - A. Organizations cannot get certified against ISO/IEC 27032
 - B. Organizations can get certified against ISO/IEC 27035-1

- C. Organizations can get certified against ISO/IEC 27035-2
- 3. **Which standard provides guidelines for security practices for stakeholders in the cyberspace?**
 - A. ISO/IEC 27032
 - B. ISO/IEC 27035-1
 - C. ISO/IEC 27035-2
- 4. **What is a Security Operations Center (SOC) team?**
 - A. A group of information security program coordinators
 - B. A group of expert individuals, security analysts, engineers, and managers who supervise security operations
 - C. A group of internal auditors who manage operational activities of the organization
- 5. **The top management must ensure that all members within the ISMS scope understand the value and importance of an effective information security incident management policy.**
 - A. True
 - B. False

Quiz 21: Management of security operations (Part 2)

- 1. **Upon receiving an event report, the operations support group completes the information security event ticket, analyzes it, and determines its priority. Which incident management process is this?**
 - A. Initial assessment and decision
 - B. Detection and reporting
 - C. Second evaluation and confirmation of an incident
- 2. **Which of the following is a responsibility of the incident management team?**

- A. Development and approval of the information security policy and monitoring of risk assessment process
 - B. Constant monitoring of targets, proactive monitoring and responses, and log management
 - C. Regular audits of the organization's compliance to ISO/IEC 27001 regarding incident response
- 3. What are the four main steps in forensic analysis?**
- A. Analyze, prepare, review, and improve
 - B. Understand, collect, archive, and report
 - C. Collect, examine, analyze, and report
- 4. What should organizations do with regard to the incident management process?**
- A. Measure it using performance indicators
 - B. Reevaluate it to identify corrective and preventive actions
 - C. Both A and B
- 5. Which of the following statements regarding business continuity (BC) is correct?**
- A. It defines the dangers that threaten an organization
 - B. It deals with the direct impact of an event
 - C. It involves stopping the incident's effects as quickly as possible and immediately addressing its consequences

Scenario-based quiz 3

EcoVista Energy Global (EVEG) is an innovative sustainability-focused company founded in 2015, in Amsterdam, Netherlands. It operates internationally and has established a significant presence in Europe, South East Asia, and North America. *EVEG* specializes in providing eco-friendly and energy-efficient solutions to businesses and industries seeking to reduce their negative impact in the environment. The company offers a wide range of renewable energy solutions, including solar power systems, wind energy installations, and biomass conversion technologies. As *EVEG* grew and expanded its operations globally, ensuring the security of its information and systems became crucial. As such, the top management of *EVEG* decided to implement an information security management system (ISMS) based on ISO/IEC 27001.

Following a comprehensive risk assessment, the ISMS team identified the information security controls from Annex A of ISO/IEC 27001 that were critical for the organization's security posture.

To safeguard its sensitive data, the ISMS team implemented robust access control systems to ensure that employees have access only to the information that is necessary for their roles. In addition, multi-factor authentication (MFA) was also introduced for privileged accounts, to further reduce the risk of unauthorized access. Furthermore, *it* also recognized the importance of segregating conflicting duties and responsibilities within the organization. As part of the security measures, the top management ensured that employees' roles and responsibilities are clearly defined, and conflicting duties are separated to prevent potential abuse or unauthorized access to sensitive information.

The ISMS team also addressed the need to maintain information security at an appropriate level during disruptions. The ISMS team determined that unforeseen events, such as natural disasters, cyberattacks, or system failures can potentially impact *EVEG's* operations and information security. For this reason, *the ISMS team* diligently planned and prepared for such disruptions, ensuring that information security remains robust and effective even in challenging circumstances.

The ISMS team also determine that it is critical to maintain backup copies of information, software, and systems. As such, it established a comprehensive and topic-specific policy on backup, ensuring that regular backup copies are created and maintained securely.

In addition to the focus on access controls, multi-factor authentication, and contingency planning, *the ISMS team* prioritized the protection of *EVEG's* valuable intellectual property and ensuring the secure use of sensitive information. The team decided to implement controls that define effective rules for the use of cryptographic techniques, including cryptographic key management. Furthermore, *to* protect intellectual property rights, the team implemented appropriate procedures to safeguard their valuable intellectual assets from unauthorized use, replication, or infringement.

The ISMS team failed to conduct a thorough cost analysis for the implementation of the controls. Thus, it allocated insufficient resources in certain areas. The team encountered challenges in effectively defining and implementing the rules for cryptographic key management, compromising the security of its sensitive information. The lack of adequate resources and preparation also led to gaps in its backup and recovery procedures. As a result, the company was not able to test the effectiveness of the backup procedures which would ensure recoverability of data and systems in case of disruptions.

Based on the scenario above, answer the following questions:

1. **What type of control did *EVEG* diligently implement to prepare for disruptions and ensure that its information security remains robust and effective even during challenging circumstances?**
 - A. A technological control
 - B. A physical control
 - C. An organizational control
2. **Will *EVEG* be able to ensure recovery from loss of data or systems?**
 - A. Yes, because it has properly implemented all the necessary controls
 - B. No, because it has not properly implemented Annex A 8.13 *Information backup* of Annex A
 - C. No, because it has not properly implemented Annex A 5.29 *Information security during disruption* of Annex A
3. **In an effort to reduce the risk of fraud, error and bypassing of information security controls, which of the following controls was implemented to distribute responsibilities within the company?**
 - A. Annex A 5.2 *Information security roles and responsibilities*
 - B. Annex A 5.3 *Segregation of duties*
 - C. Annex A 5.4 *Management responsibilities*
4. **What did the ISMS team do to ensure the reliability and recoverability of its data and systems in case of disruptions?**
 - A. It established a backup policy
 - B. By conducting regular backups
 - C. Both A and B
5. **By not conducting a comprehensive cost analysis, what did *EVEG* fail to do effectively?**
 - A. Prepare for the implementation of controls
 - B. Design and describe the controls
 - C. Evaluate the effectiveness of controls

Quiz 22: Monitoring, measurement, analysis, and evaluation

- 1. When planning the monitoring, measurement, analysis, and evaluation, organizations should define their “information need,” which is a high level information security question or statement that helps the organization evaluate information security performance, so that these evaluations meet the defined information need.**
 - A. True
 - B. False
- 2. What is measurement?**
 - A. The process of observing a system, process, or product to determine its performance levels
 - B. The process of determining the value and traits of a system, process, or product
 - C. The process of examining a system, process, or product in order to understand it better
- 3. Which of the following statements regarding ISO/IEC 27004 is correct?**
 - A. ISO/IEC 27004 provides guidelines to help organizations in evaluating the ISMS performance
 - B. Organizations can obtain certification against ISO/IEC 27004
 - C. ISO/IEC 27004 does NOT elaborate on what and when to monitor and measure
- 4. Which aspect do strategic dashboards primarily focus on?**

- A. Detailed operational tasks and daily activities within the organization
 - B. High-level measures of performance and forecasts for decision-makers
 - C. Individual employee performance evaluations
5. **According to ISO/IEC 27004, which of the following processes and activities are NOT subject to measurement?**
- A. Financing and business management
 - B. Communicating and documenting
 - C. Planning and auditing

Quiz 23: Internal audit

1. **What does ISO 19011 provide?**
 - A. Requirements for bodies providing audit and certification services
 - B. Guidelines regarding the necessary competencies that auditors must possess to audit an ISMS
 - C. Guidance on managing an audit program and planning and conducting management system audits
2. **Who is responsible for undertaking the required and appropriate measures after the audit results are communicated?**
 - A. The top management
 - B. The audit team
 - C. The external consultants
3. **Internal audits are known as second party audits.**
 - A. True
 - B. False
4. **Which of the following statements regarding internal audits is NOT correct?**
 - A. Internal audits do not have an advisory role within the organization
 - B. Internal audits consider the effectiveness and efficiency of the ISMS
 - C. Internal audits are independent of the audited activities
5. **Which of the following is a responsibility of an internal auditor?**
 - A. Planning the audit activities
 - B. Establishing the extent of the audit program

- C. Allocating the necessary resources for the internal audit program
- 6. **What is the correct definition of a nonconformity?**
 - A. Failure to communicate with stakeholders effectively
 - B. Temporary interruption of services due to maintenance
 - C. Non-fulfilment of a requirement
- 7. **Organizations must correct all nonconformities simultaneously.**
 - A. True
 - B. False

Quiz 24: Management review

- 1. **An organization wishing to comply with ISO/IEC 27001 must conduct management reviews at planned intervals.**
 - A. True
 - B. False
- 2. **Who is responsible for ensuring that follow-up action plans are approved by the top management?**
 - A. The ISMS coordinator and the internal audit team
 - B. The ISMS project manager
 - C. The information security manager
- 3. **Which of the following does NOT need to be included in the management review?**
 - A. Feedback on employee performance
 - B. Feedback from interested parties
 - C. Feedback on the information security performance
- 4. **What should be included in the management review outputs, among others?**
 - A. Decisions related to risk treatment opportunities
 - B. Decisions related to continual improvement opportunities
 - C. Both A and B
- 5. **According to ISO/IEC 27001, what information should be documented when a management review is conducted?**
 - A. Monitoring and measurement results
 - B. Risk assessment results
 - C. Both A and B

Quiz 25: Treatment of nonconformities

- 1. An action taken to eliminate the cause of a nonconformity and to prevent recurrence is known as:**
 - A. Correction
 - B. Corrective action
 - C. Preventive action
- 2. According to ISO/IEC 27001, who is responsible to review the effectiveness of any corrective actions taken when a nonconformity occurs?**
 - A. The organization
 - B. The internal auditor
 - C. The ISMS project manager
- 3. What should an action plan include?**
 - A. An implementation time frame
 - B. The costs of the corrective measures
 - C. The evidence of the identified nonconformity
- 4. All nonconformities should be included in a single inclusive action plan instead of preparing one action plan for each nonconformity.**
 - A. True
 - B. False
- 5. What happens if the auditee has not submitted the action plans within the specified deadline?**
 - A. The auditee will have to request for another submission date
 - B. The auditor will issue a major nonconformity
 - C. The auditee will not be recommended for certification

6. **What activities are included in the situation analysis phase of the corrective action process, among others?**
- A. Identification and documentation of the nonconformities
 - B. Follow-up on and review of corrective actions
 - C. Evaluation of options and selection of solutions

Quiz 26: Continual improvement

1. **Which of the following are NOT considered as an ISMS change factor that need to be monitored?**
- A. Changes in technologies
 - B. Organizational changes
 - C. Product reviews
2. **What does the frequency of reviewing an organization's ISMS depend on?**
- A. The number of employees in the organization, its annual revenues, and its geographical location
 - B. The organization's compliance with industry regulations, customer feedback, and employee satisfaction
 - C. The nature, scale, and complexity of the organization, its business risk profile, and the environment in which it operates
3. **Continual improvement has no impact on team collaboration.**
- A. True
 - B. False
4. **Organization A evaluates and updates (if necessary) its ISMS processes every year to make sure they are effective. Is a good practice?**
- A. No, ISMS processes should be regularly evaluated and updated
 - B. Yes, ISO 27001 requires organizations to evaluated and updated on a yearly basis
 - C. No, ISMS processes should be evaluated and updated only when nonconformities are detected
5. **What is accomplished when the ISMS processes and information security controls are compatible with the organization's overall purposes, activities, and processes?**

- A. Suitability
- B. Adequacy
- C. Effectiveness

Quiz 27: Preparing for the certification audit

1. **During which phase of the ISMS certification process is the stage 2 audit conducted?**
 - A. Before the audit
 - B. Initial audit
 - C. Beyond the audit
2. **Which of the following is NOT a valid reason for rejecting an auditor?**
 - A. The auditor has recently audited a major competitor of the auditee
 - B. The auditor has audited the organization in past
 - C. The auditor has worked for one of the organization's competitors
3. **What is the main activity of the stage 1 audit?**
 - A. Verifying the efficiency of the management system
 - B. Reviewing the documented information
 - C. Evaluating compliance with the requirements of the standard
4. **The auditor issues the final certification decision upon concluding the audit.**
 - A. True
 - B. False
5. **What is the aim of the audit follow-up?**
 - A. To validate the operational control of the auditee's processes
 - B. To verify the "design" of the management system
 - C. To validate the action plans and corrective action plans submitted by the auditee

Scenario-based quiz 4

Markt is a renowned recruiting company that specializes in finding qualified employees for various positions required by other companies. The company operates in a competitive industry where the need for maintaining client and candidate data confidentiality, integrity, and availability is vital. *Markt* handles sensitive information, including personal details, contact information, and sometimes even financial data of both candidates and clients. Recognizing the importance of ensuring information security, *Markt* decided to implement an information security management system (ISMS) based on ISO/IEC 27001. Upon the implementation of ISO/IEC 27001 requirements, *Markt* decided to conduct an internal audit as part of performance evaluation of its ISMS. The company's top management appointed Lisa as the internal auditor to plan arrangements for one audit to evaluate whether the ISMS conforms to *Markt*'s requirements for the ISMS and the requirements of ISO/IEC 27001. Lisa was assigned the responsibility for determining the required resources for the audit program.

Lisa established the audit program objectives and proceeded to implement the planned arrangements. However, she did not determine and evaluate the audit program risks and opportunities as she believed that the company operates in a low-risk environment with minimal changes in its processes or regulation. To ensure a comprehensive assessment of the ISMS, Lisa carefully planned the main activities in accordance with the objectives of the audit program. Her planned audit activities included reviewing the company's application of internal policies, procedures, and other relevant documented information, the effectiveness of the company's operations and risk assessment process, and the level of conformity to relevant laws, regulations and the standard's requirements.

After collecting sufficient audit evidence, Lisa evaluated it against the audit criteria and drafted the audit findings. After analyzing and reviewing the findings taking the audit objectives into consideration, she issued the audit conclusions, which indicated both areas of conformity and nonconformity. The nonconformities detected by Lisa during the audit were documented in a nonconformity report. After receiving this report, *Markt* initially analyzed the root cause of the identified nonconformities, and then selected appropriate corrective actions to address them.

Based on the scenario above, answer the following questions:

1. **The top management assigned Lisa the responsibility for determining the resources needed for the audit program. Is this in accordance with best practices?**
 - A. No, determining the resources for the audit program is the responsibility of the Financial Department
 - B. No, determining the resources for the audit program is solely the responsibility of the top management
 - C. Yes, the individual managing the audit program can determine resources for the audit program

2. **After establishing the audit program objectives, Lisa decided not to determine and evaluate the audit program risks and opportunities as she believed that the company operates in a low-risk environment with minimal changes in its processes or regulation. Is this in alignment with best practices?**
 - A. No, after establishing audit program objectives, audit program risks and opportunities should be determined and evaluated
 - B. Yes, it is not necessary to evaluate audit program risks and opportunities if the organization operates in a low-risk environment with minimal changes
 - C. No, the internal auditor must not establish audit program objectives as this responsibility is within the authority of the top management

3. **To ensure a comprehensive assessment of the ISMS, Lisa carefully planned the main activities in accordance with the objectives of the audit program. Which of the following activities is considered as part of the main activities that Lisa should have planned to undertake during the audit?**
 - A. Reviewing the allocation and utilization of resources within the company
 - B. Investigating customer complaints
 - C. Examining the company's supply chain management

4. **After receiving the nonconformity report, Markt initially analyzed the root cause of the identified nonconformities, and then selected appropriate corrective actions to address them. Is this in compliance with best practices?**
 - A. No, organizations should conduct a situation analysis before addressing a nonconformity
 - B. No, organizations should analyze one or more possible solutions for addressing the nonconformities before analyzing their root causes
 - C. Yes, organizations should analyze the root causes of nonconformities before determining the adequate corrective actions

5. **Did Lisa issue the audit conclusions in alignment with best practices?**

- A. Yes, Lisa issued the conclusions after reviewing the audit findings, taking into consideration the audit objectives
- B. No, Lisa should have reviewed the audit findings in collaboration with the ISMS project manager of the company, and then issued the audit conclusions
- C. No, Lisa should have submitted the audit findings to the top management, who then can issue the audit conclusions